NIST Cybersecurity Framework 2.0 (CSF 2.0)

Faculty of Computer Science and Engineering, GIK

Where CSF applies

The Core applies across technology environments—not just traditional enterprise IT.

IT

Endpoints, servers, identity, applications, networks

Cloud

IaaS/PaaS/SaaS, cloud identities, configurations, provider risk

Mobile

Mobile apps, device management, authentication, data protection

IoT

Sensors, devices, firmware, device identity and lifecycle

OT

Industrial control, physical processes, safety and resilience

AI

Models, data, pipelines, agents, APIs and AI supply chains

NIST CSF 2.0

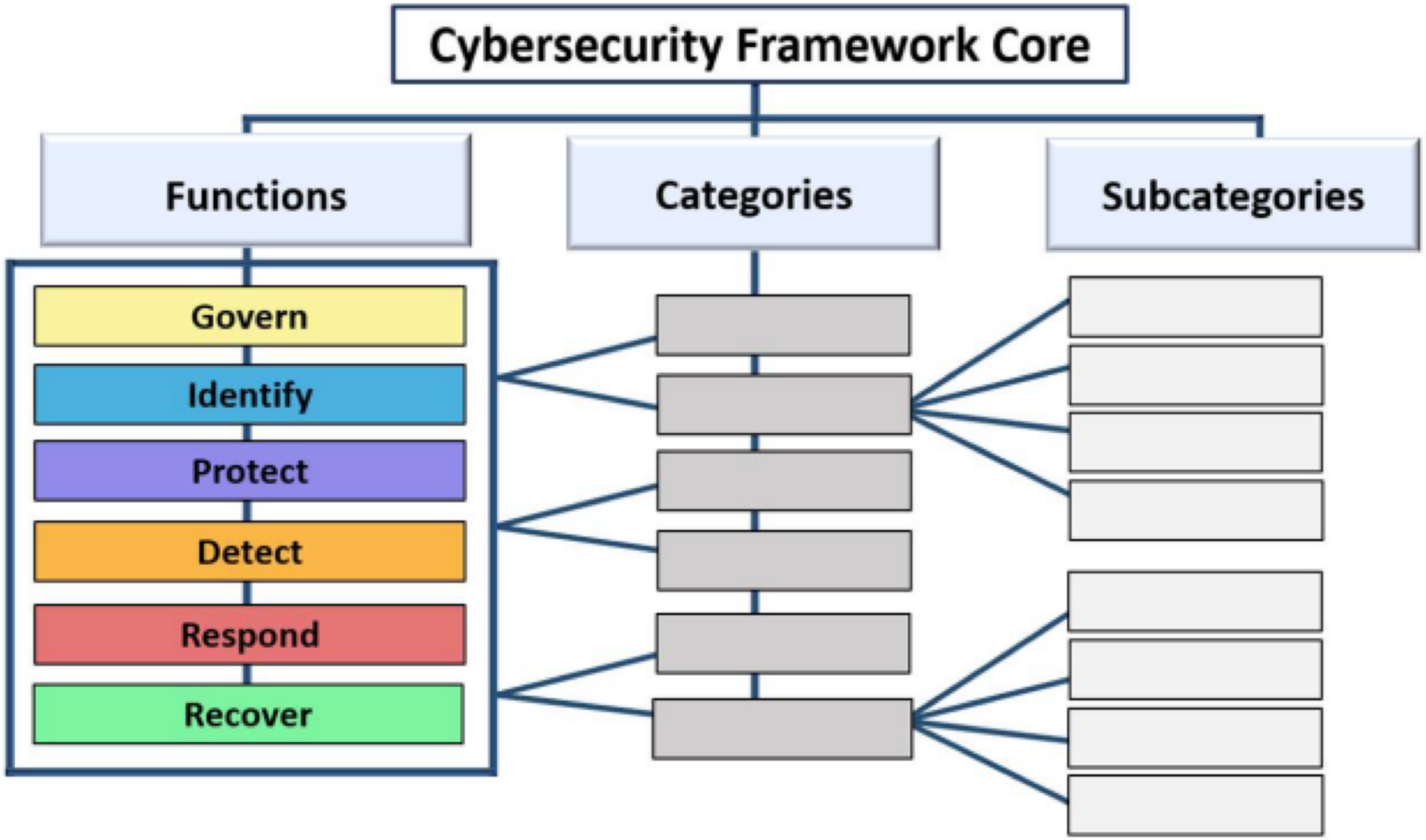
Purpose

- Help organizations understand, assess, prioritize, and communicate cybersecurity risk.
- Works across industry, government, academia, and nonprofit organizations.
- Technology-, sector-, and country-neutral; tailored to mission, risk appetite, and resources.

What CSF 2.0 provides

- CSF Core: Functions, Categories, Subcategories.
- Organizational Profiles: Current and Target posture.
- CSF Tiers: rigor of governance and risk management.
- Online resources: Implementation Examples, Informative References, Quick-Start Guides, Community Profiles.

The CSF 2.0 hierarchy



The CSF 2.0 hierarchy

FUNCTION

Highest-level outcome grouping. Six Functions: GV, ID, PR, DE, RS, RC.

CATEGORY

Related cybersecurity outcomes within a Function. CSF 2.0 has 22 Categories.

SUBCATEGORY

More specific technical and management outcomes. Identifiers such as GV.OC-01 or PR.AA-05.

Outcome ≠ control

A Subcategory says what desirable outcome should exist. The organization decides how to achieve it.

PR.AA-05 : access permissions, entitlements, and authorizations are defined, managed, enforced and reviewed, incorporating least privilege and separation of duties.

The six CSF Functions

The Functions are concurrent and continuous; GOVERN informs how the other five are implemented.

ID IDENTIFY

Understand current cybersecurity risk

PR PROTECT

Use safeguards to manage risk

GV GOVERN

Strategy, expectations, policy, oversight

RS RESPOND

Take action on detected incidents

DE DETECT

Find and analyze possible attacks/compromises

RC RECOVER

Restore assets and operations

GOVERN is shown at the center because it informs the implementation and prioritization of the other Functions.

Govern

CSF 2.0 Function • GV

GV

GOVERN

What must leadership understand, decide, communicate, resource, and oversee so cybersecurity becomes part of enterprise risk management?

Key Idea

Cybersecurity is a governance problem before it is a tooling problem.

Identify

CSF 2.0 Function • ID

ID

IDENTIFY

What this Function answers

What assets, dependencies, vulnerabilities, threats, impacts, and improvement opportunities exist and which matter most?

Key idea

You cannot protect what you do not know.

Protect

CSF 2.0 Function • PR

PR

PROTECT

What this Function answers

What safeguards reduce the likelihood and impact of adverse cybersecurity events after risks have been identified and prioritized?

Key idea

Turn identified risk into concrete safeguards.

Detect

CSF 2.0 Function • DE

DE

DETECT

What this Function answers

How will the organization continuously discover anomalies, indicators of compromise, and potentially adverse events?

Key idea

Know quickly when reality diverges from the expected state.

Respond

CSF 2.0 Function • RS

RS

RESPOND

What this Function answers

Once an incident is declared, how will the organization manage, analyze, communicate, contain, and eradicate it?

Key idea

Contain, analyze, communicate, and mitigate the incident.

Recover

CSF 2.0 Function • RC

RC

RECOVER

What this Function answers

How will the organization restore trustworthy operations, verify restored assets, communicate progress, and close recovery?

Key idea

Restore trustworthy operations and learn from the event.

Govern: Categories at a glance

GV Function • 6 Categories

GV.OC Organizational Context

Mission, stakeholders, dependencies, and requirements

GV.RM Risk Management Strategy

Risk appetite, tolerance, strategy, ERM and prioritization

GV.RR Roles, Responsibilities, and Authorities

Accountability, roles, authorities, resources and HR

GV.PO Policy

Establish, communicate and enforce policy

GV.OV Oversight

Measure, review and adjust cybersecurity strategy

GV.SC Cybersecurity Supply Chain Risk Management

Manage cyber supply-chain risk across the lifecycle

Identify: Categories at a glance

ID Function • 3 Categories

ID.AM Asset Management

Know assets, data, services, flows and lifecycles

ID.RA Risk Assessment

Understand vulnerabilities, threats, impacts and responses

ID.IM Improvement

Continuously identify and institutionalize improvements

Protect: Categories at a glance

PR Function • 5 Categories

PR.AA Identity Management, Authentication, and Access Control
Identity, authentication, authorization and physical access

PR.AT Awareness and Training

Cybersecurity awareness and role-based training

PR.DS Data Security

Protect data at rest, in transit, in use and backups

PR.PS Platform Security

Configuration, lifecycle, logging, unauthorized software and secure SDLC

PR.IR Technology Infrastructure Resilience

Resilience of networks, environments, facilities and capacity

Detect: Categories at a glance

DE Function • 2 Categories

DE.CM Continuous Monitoring

Monitor networks, physical environment, people, providers and systems

DE.AE Adverse Event Analysis

Analyze, correlate, contextualize and declare incidents

Respond: Categories at a glance

RS Function • 4 Categories

RS.MA Incident Management

Triage, prioritize, escalate and manage incidents

RS.AN Incident Analysis

Forensic investigation, provenance and impact analysis

RS.CO Incident Response Reporting and Communication

Stakeholder notification and information sharing

RS.MI Incident Mitigation

Contain and eradicate incidents

Recover: Categories at a glance

RC Function • 2 Categories

RC.RP Incident Recovery Plan Execution

Execute recovery, verify integrity, restore and close

RC.CO Incident Recovery Communication

Communicate recovery progress and public updates

GV.OC — Organizational Context

Govern • Subcategories 1/1

GV.OC-01

Mission informs cybersecurity risk management

GV.OC-02

Internal/external stakeholders and expectations are understood

GV.OC-03

Legal, regulatory, contractual, privacy and civil-liberties requirements are managed

GV.OC-04

Critical objectives, capabilities and services expected by external stakeholders are understood

GV.OC-05

Organizational dependencies, capabilities and services are understood

GV.RM — Risk Management Strategy

Govern • Subcategories 1/1

GV.RM-01

Risk-management objectives are established and agreed

GV.RM-02

Risk appetite and tolerance are established and maintained

GV.RM-03

Cybersecurity risk management is included in enterprise risk management

GV.RM-04

Strategic direction defines appropriate risk-response options

GV.RM-05

Communication lines for cybersecurity risks, including suppliers, are established

GV.RM-06

Standardized risk calculation/documentation/categorization/prioritization exists

GV.RM-07

Positive risks / strategic opportunities are included in cybersecurity discussions

GV.RR — Roles, Responsibilities, and Authorities

Govern • Subcategories 1/1

GV.RR-01

Leadership is accountable for cybersecurity risk and fosters a risk-aware culture

GV.RR-02

Cybersecurity roles, responsibilities and authorities are established and enforced

GV.RR-03

Resources are allocated commensurate with cybersecurity risk

GV.RR-04

Cybersecurity is included in human-resources practices

GV.PO — Policy

Govern • Subcategories 1/1

GV.PO-01

Cybersecurity risk-management policy is established, communicated and enforced

GV.PO-02

Policy is reviewed and updated for requirements, threats, technology and mission changes

GV.OV — Oversight

Govern • Subcategories 1/1

GV.OV-01

Strategy outcomes are reviewed to inform direction

GV.OV-02

Strategy is reviewed/adjusted for organizational requirements and risks

GV.OV-03

Cybersecurity performance is evaluated and reviewed

GV.SC — Cybersecurity Supply Chain Risk Management

Govern • Subcategories 1/2

GV.SC-01

C-SCRM program, strategy, objectives, policies and processes are established

GV.SC-02

Supplier/customer/partner cybersecurity roles are coordinated

GV.SC-03

C-SCRM is integrated with cybersecurity, ERM, assessment and improvement

GV.SC-04

Suppliers are known and prioritized by criticality

GV.SC-05

Supply-chain security requirements are integrated into contracts/agreements

GV.SC-06

Planning and due diligence occur before third-party relationships

GV.SC-07

Supplier/product/service risks are recorded, assessed, responded to and monitored

GV.SC — Cybersecurity Supply Chain Risk Management

Govern • Subcategories 2/2

GV.SC-08

Relevant third parties participate in incident planning, response and recovery

GV.SC-09

Supply-chain practices are monitored throughout the technology life cycle

GV.SC-10

Plans address activities after partnership/service conclusion

ID.AM — Asset Management

Identify • Subcategories 1/1

ID.AM-01

Hardware inventories are maintained

ID.AM-02

Software, services and systems inventories are maintained

ID.AM-03

Authorized network communications and data-flow representations are maintained

ID.AM-04

Supplier-provided service inventories are maintained

ID.AM-05

Assets are prioritized by classification, criticality, resources and mission impact

ID.AM-07

Data and corresponding metadata inventories are maintained

ID.AM-08

Systems, hardware, software, services and data are managed through their life cycles

ID.RA — Risk Assessment

Identify • Subcategories 1/2

ID.RA-01

Asset vulnerabilities are identified, validated and recorded

ID.RA-02

Cyber threat intelligence is received from information-sharing sources

ID.RA-03

Internal and external threats are identified and recorded

ID.RA-04

Threat impacts and likelihoods are identified and recorded

ID.RA-05

Threats, vulnerabilities, likelihoods and impacts inform inherent risk and prioritization

ID.RA-06

Risk responses are chosen, prioritized, planned, tracked and communicated

ID.RA-07

Changes and exceptions are risk-assessed, recorded and tracked

ID.RA — Risk Assessment

Identify • Subcategories 2/2

ID.RA-08

Vulnerability disclosure intake/analysis/response processes exist

ID.RA-09

Hardware/software authenticity and integrity are assessed before acquisition/use

ID.RA-10

Critical suppliers are assessed before acquisition

ID.IM — Improvement

Identify • Subcategories 1/1

ID.IM-01

Improvements are identified from evaluations

ID.IM-02

Improvements are identified from security tests and exercises

ID.IM-03

Improvements are identified from operational processes and activities

ID.IM-04

Incident-response and other operational cybersecurity plans are established, maintained and improved

PR.AA — Identity Management, Authentication, and Access Control

Protect • Subcategories 1/1

PR.AA-01

Identities and credentials for users, services and hardware are managed

PR.AA-02

Identities are proofed and bound to credentials according to interaction context

PR.AA-03

Users, services and hardware are authenticated

PR.AA-04

Identity assertions are protected, conveyed and verified

PR.AA-05

Permissions/entitlements/authorizations use policy, least privilege and separation of duties

PR.AA-06

Physical access is managed, monitored and enforced according to risk

PR.AT — Awareness and Training

Protect • Subcategories 1/1

PR.AT-01

Personnel receive awareness/training for general cybersecurity-risk-aware tasks

PR.AT-02

Specialized-role personnel receive role-relevant cybersecurity training

PR.DS — Data Security

Protect • Subcategories 1/1

PR.DS-01

Confidentiality, integrity and availability of data-at-rest are protected

PR.DS-02

Confidentiality, integrity and availability of data-in-transit are protected

PR.DS-10

Confidentiality, integrity and availability of data-in-use are protected

PR.DS-11

Backups are created, protected, maintained and tested

PR.PS — Platform Security

Protect • Subcategories 1/1

PR.PS-01

Configuration-management practices are established and applied

PR.PS-02

Software is maintained, replaced and removed according to risk

PR.PS-03

Hardware is maintained, replaced and removed according to risk

PR.PS-04

Log records are generated and available for continuous monitoring

PR.PS-05

Unauthorized software installation/execution is prevented

PR.PS-06

Secure software-development practices are integrated and monitored across the SDLC

PR.IR — Technology Infrastructure Resilience

Protect • Subcategories 1/1

PR.IR-01

Networks and environments are protected from unauthorized logical access/use

PR.IR-02

Technology assets are protected from environmental threats

PR.IR-03

Resilience mechanisms address normal and adverse situations

PR.IR-04

Adequate resource capacity is maintained for availability

DE.CM — Continuous Monitoring

Detect • Subcategories 1/1

DE.CM-01

Networks and network services are monitored

DE.CM-02

Physical environment is monitored

DE.CM-03

Personnel activity and technology usage are monitored

DE.CM-06

External service-provider activities/services are monitored

DE.CM-09

Hardware, software, runtime environments and data are monitored

DE.AE — Adverse Event Analysis

Detect • Subcategories 1/1

DE.AE-02

Potentially adverse events are analyzed to understand associated activity

DE.AE-03

Information is correlated from multiple sources

DE.AE-04

Estimated impact and scope are understood

DE.AE-06

Event information is provided to authorized staff and tools

DE.AE-07

Threat intelligence/context are integrated into analysis

DE.AE-08

Incidents are declared when defined criteria are met

RS.MA — Incident Management

Respond • Subcategories 1/1

RS.MA-01

Incident-response plan is executed with relevant third parties

RS.MA-02

Incident reports are triaged and validated

RS.MA-03

Incidents are categorized and prioritized

RS.MA-04

Incidents are escalated/elevated as needed

RS.MA-05

Criteria for initiating incident recovery are applied

RS.AN — Incident Analysis

Respond • Subcategories 1/1

RS.AN-03

Investigation establishes what happened and root cause

RS.AN-06

Investigation actions are recorded; integrity/provenance preserved

RS.AN-07

Incident data/metadata are collected; integrity/provenance preserved

RS.AN-08

Incident magnitude is estimated and validated

RS.CO — Incident Response Reporting and Communication

Respond • Subcategories 1/1

RS.CO-02

Internal and external stakeholders are notified

RS.CO-03

Information is shared with designated stakeholders

RS.MI — Incident Mitigation

Respond • Subcategories 1/1

RS.MI-01

Incidents are contained

RS.MI-02

Incidents are eradicated

RC.RP — Incident Recovery Plan Execution

Recover • Subcategories 1/1

RC.RP-01

Recovery portion of incident-response plan is executed

RC.RP-02

Recovery actions are selected, scoped, prioritized and performed

RC.RP-03

Backup/restoration-asset integrity is verified before restoration

RC.RP-04

Critical mission functions and risk management inform post-incident norms

RC.RP-05

Restored assets are verified; systems/services restored; normal operation confirmed

RC.RP-06

End of recovery is declared using criteria and documentation completed

RC.CO — Incident Recovery Communication

Recover • Subcategories 1/1

RC.CO-03

Recovery activities and progress are communicated to designated stakeholders

RC.CO-04

Public recovery updates use approved methods and messaging

CSF Organizational Profiles

Profiles describe current and/or target cybersecurity posture using Core outcomes.

Current Profile

What the organization is currently achieving (or attempting to achieve), and to what extent/how.

Target Profile

Desired Core outcomes selected and prioritized for cybersecurity objectives, considering future requirements, technology and threat trends.

The practical question: “Where are we now, where do we need to be, and what risk-informed work closes the gap?”

Building a CSF Organizational Profile

A repeatable five-step cycle for assessment and continuous improvement.

1. Scope

Define the organization/system/use case, assumptions and boundaries.

2. Gather

Collect policies, risk priorities, resources, BIA, requirements, standards, practices, tools and roles.

3. Create

Document selected Core outcomes and current state; use a Community Profile where useful.

4. Analyze gaps

Compare Current vs Target; create prioritized actions such as a risk register or POA&M.

Building a CSF Organizational Profile



References

- Mano Paul - Official (ISC)2 Guide to the CSSLP CBK (2013, Auerbach Publications) - libgen.li

- NIST Cybersecurity Framework (CSF) 2.0

Questions?